

Security Audit & Risk Assessment

Botium Toys

Portfolio project completed as part of the Google Cybersecurity Professional Certificate
Fictional organization used for training purposes

Executive Summary

This internal security audit evaluated the security controls and compliance practices of Botium Toys, a fictional U.S.-based toy company with a physical office, storefront, warehouse, and growing international online presence. The assessment identified gaps in access control, business continuity, monitoring, data protection, and password management, along with compliance concerns related to PCI DSS, GDPR, and SOC practices. Remediation recommendations were developed to reduce organizational risk and improve the company's overall security posture.

1. Audit Scope & Objective

The audit covered Botium Toys' security program, including employee equipment and devices, the internal network, systems, security controls, and relevant compliance practices. The objective was to assess existing safeguards, identify control and compliance gaps, and recommend improvements that would reduce risk to assets and support business continuity.

2. Controls Assessment

Control	Status
Least privilege	Not implemented
Disaster recovery plans	Not implemented
Password policies	Implemented
Separation of duties	Not implemented
Firewall	Implemented
Intrusion detection system (IDS)	Not implemented
Backups	Not implemented
Antivirus software	Implemented
Manual monitoring / maintenance of legacy systems	Implemented
Encryption	Not implemented
Password management system	Not implemented
Physical locks	Implemented
CCTV surveillance	Implemented
Fire detection / prevention	Implemented

3. Compliance Assessment

PCI DSS: The assessment found that the reviewed best practices were not currently met, including restricting access to cardholder information, securing payment-card data, encrypting transaction data, and adopting secure password-management practices.

GDPR: The assessment found a gap in keeping E.U. customer data private and secure. The reviewed materials indicated that breach-notification planning, data classification and inventory, and privacy policies/processes were in place.

SOC practices: User access policies were not established and PII/SPII was not kept confidential/private. Data integrity and availability practices were identified as present.

4. Key Security Risks

- Lack of least-privilege controls
- No disaster recovery plan

- Lack of separation of duties
- No intrusion detection system (IDS)
- No backups of critical data
- No encryption of credit card information
- No centralized password management system

5. Recommended Controls

Identified Gap	Recommended Control
Least privilege	Restrict access to PII/SPII to personnel who require it for their job responsibilities.
Disaster recovery	Use the NIST Cybersecurity Framework (CSF) and NIST Risk Management Framework (RMF) as references when developing a disaster recovery plan.
Separation of duties	Compartmentalize roles and access privileges so personnel receive only the access needed to perform their responsibilities.
Intrusion detection	Identify and implement a reliable intrusion detection system.
Critical-data backups	Create an automated backup protocol to support data integrity and recovery.
Payment-card encryption	Implement encryption controls to protect credit card information.
Password management	Establish minimum password-security requirements and implement centralized password-management controls.

6. Compliance Remediation

Recommended remediation for the identified compliance gaps included applying least privilege, separation of duties, and encryption controls to address PCI DSS and GDPR concerns; establishing user-access policies; and strengthening controls protecting the confidentiality of PII/SPII. The original assessment also recommended review by an Identity and Access Management function when refining access-control proposals.

7. Conclusion

The assessment identified meaningful gaps in Botium Toys' security controls and compliance practices. Implementing the recommended safeguards would reduce risk to organizational assets, strengthen data protection and business continuity, and improve the organization's overall security posture.

Skills demonstrated: Security auditing, risk assessment, security controls, access control, least privilege, vulnerability identification, PCI DSS, GDPR, SOC, NIST CSF, security documentation, and remediation planning.